



République Tunisienne

Ministère de l'Enseignement Supérieur et de la Recherche
Scientifique

Université de Monastir

Institut Supérieur d'Informatique et de Mathématiques de
Monastir

Département d'Informatique



Projet de Sécurité Informatique

Présenté par :

Ranim Bouraoui
Mahmoud Ben Abdelkader

Encadré par :

Dr. Wafa Berrayana

APPLICATION BANCAIRE SECURISEE
SecureBank

Diplôme National d'Ingénieur en Sciences Informatique

Spécialité : *Génie Logiciel*

_____ **Année Universitaire : 2025–2026** _____

Introduction Generale	1
I Analyse des Besoins	2
1 Besoins fonctionnels	2
2 Besoins non fonctionnels	2
2.1 Securite	2
2.2 Performance	3
2.3 Fiabilite	3
3 Diagramme de contexte	3
II Specifications Fonctionnelles et Securitaires	4
1 Authentification JWT	4
1.1 Tokens	4
1.2 Securite des tokens	4
2 Systeme OTP (One-Time Password)	5
2.1 Utilisation	5
2.2 Caracteristiques	5
3 Gestion des permissions	5
III Conception Technique	6
1 Architecture generale	6
1.1 Stack technologique	6
1.2 Architecture en couches	6

2	Diagramme de classes global	7
2.1	Description	7
2.2	Inclusion du diagramme	8
3	Diagrammes de séquence	9
3.1	Séquence : Connexion / Inscription (Sign Up / Sign In)	9
3.2	Séquence : Gestion des bénéficiaires	9
3.3	Séquence : Virement avec OTP	10
3.4	Séquence : Historique des transactions	11
3.5	Séquence : Paramètres Profil & Sécurité	11
3.6	Séquence générale du flux de l'application	12
4	Diagramme d'état	14
4.1	État d'une transaction – SecureBank	14
IV Conception Securisee		16
1	Protection des mots de passe	16
1.1	Algorithme de hachage	16
1.2	Code exemple	16
2	Generation securisee des OTP	16
2.1	Caracteristiques de securite	16
2.2	Validation des OTP	17
3	Securite des comptes bancaires	17
3.1	Creation automatique	17
3.2	Verification de propriete	17
4	Chiffrement TLS/SSL	18
4.1	Configuration	18
5	Audit Logging	18
V Developpement de l'Application		19
1	Backend Django	19
1.1	Endpoints API principaux	20
2	Frontend React	21
2.1	Description generale	21
2.2	Pages principales	21

2.3	Ecran de Connexion	21
2.4	Ecran de creation compte	22
2.5	Tableau de Bord	23
2.6	Affichage des comptes bancaires depuis le tableau de bord”	25
2.7	Gestion des bénéficiaires	26
2.7.1	Liste des bénéficiaires	26
2.7.2	Ajout d’un nouveau bénéficiaire	26
2.8	Interface de virement	27
2.8.1	Formulaire de virement	27
2.8.2	Confirmation du virement	28
2.9	Vérification OTP	29
2.9.1	Écran de vérification OTP – Avant saisie	29
2.9.2	Écran de vérification OTP – Après saisie	31
2.10	Historique des transactions	31
2.11	Paramètres du profil	32
2.12	Sécurité et Two-Factor Authentication (2FA)	33
2.12.1	2FA activée	34
2.12.2	2FA désactivée	34
2.12.3	Changement de mot de passe	35
2.12.4	Déconnexion	37
3	Bases de donnees	38
3.1	PostgreSQL	38
VI	Tests de Securite	39
1	Methodologie	39
2	Test 1 : Prevention SQL Injection	39
2.1	Scenario	39
2.2	Resultats	40
3	Test 2 : Protection contre Brute Force OTP	40
3.1	Scenario	40
3.2	Resultats	41
4	Synthese des tests	41

Conclusion Generale	42
---------------------	----

TABLE DES FIGURES

III.1 Diagramme de classes principal – SecureBank	8
III.2 Diagramme de séquence – Connexion / Inscription	9
III.3 Diagramme de séquence – Gestion des bénéficiaires	10
III.4 Diagramme de séquence – Virement avec OTP	10
III.5 Diagramme de séquence – Historique des transactions	11
III.6 Diagramme de séquence – Paramètres Profil et Sécurité	12
III.7 Diagramme de séquence – Flux général de l'application SecureBank . . .	13
III.8 Diagramme d'état – Cycle de vie d'une transaction SecureBank	15
V.1 Interface de connexion - Page de login	22
V.2 Interface de connexion - Page de login	23
V.3 Tableau de bord	24
V.4 Popup affichant tous les comptes bancaires	25
V.5 Page de gestion des bénéficiaires	26
V.6 Formulaire d'ajout d'un bénéficiaire	27
V.7 Formulaire de virement avant remplissage	28
V.8 Formulaire de virement après remplissage	29
V.9 Écran de vérification OTP – Avant saisie du code	30
V.10 Écran de vérification OTP – Après saisie du code	31
V.11 Historique des transactions bancaires	32
V.12 Page des paramètres du profil utilisateur	33
V.13 Paramètres de sécurité avec 2FA activée	34

V.14 Paramètres de sécurité avec 2FA désactivée	34
V.15 Formulaire de changement de mot de passe	35
V.16 Formulaire de changement de mot de passe avec contrôle de saisie	36
V.17 Option de déconnexion du profil utilisateur	37

LISTE DES TABLEAUX

II.1	Types de tokens JWT	4
II.2	Specifications de l'OTP	5
III.1	Stack technologique utilisée	6
V.1	Tableau V.1 – Endpoints API backend	20
VI.1	Resultats du test SQL Injection	40
VI.2	Resultats du test Brute Force	41
VI.3	Synthese de tous les tests	41

INTRODUCTION GENERALE

Ce rapport présente la conception, le développement et la sécurisation d'une application bancaire moderne basée sur Django REST, React JSX et PostgreSQL.

L'objectif principal est de garantir un haut niveau de sécurité tout en offrant des fonctionnalités bancaires fiables et conformes aux normes de l'industrie financière.

Contexte du projet

Ce projet s'inscrit dans le cadre du cours de **Sécurité Informatique** (Dr. Wafa BERRYANA, AU 2025/2026). Il vise à appliquer les principes fondamentaux de la cybersécurité dans le développement d'une application sensible.

Objectifs principaux

- Concevoir une architecture sécurisée
- Implémenter des mécanismes d'authentification robustes
- Protéger les données sensibles des utilisateurs
- Effectuer des tests de sécurité complets
- Documenter les bonnes pratiques de sécurité

Structure du rapport

Ce rapport est organisé en 6 chapitres couvrant l'ensemble du cycle de vie du projet, de l'analyse des besoins à la validation sécuritaire.

CHAPITRE | _____

ANALYSE DES BESOINS

1 Besoins fonctionnels

L'application bancaire doit offrir les fonctionnalités suivantes :

- **Authentification** : Connexion sécurisée des utilisateurs.
- **Activation par OTP** : Vérification en deux étapes pour renforcer la sécurité.
- **Gestion des comptes** : Création et gestion des comptes bancaires.
- **Gestion des bénéficiaires** : Ajout et modification des destinataires.
- **Virements bancaires** : Transferts d'argent sécurisés.
- **Historique des transactions** : Consultation des mouvements financiers.
- **Mise à jour du profil** : Modification des données personnelles.

2 Besoins non fonctionnels

2.1 Sécurité

- Chiffrement TLS/SSL pour toutes les communications
- Authentification JWT avec tokens
- OTP pour les actions sensibles
- Hachage sécurisé des mots de passe
- Audit logging complet

2.2 Performance

- Temps de reponse API < 500ms
- Support de 1000+ utilisateurs simultanees
- Optimisation des requetes base de donnees

2.3 Fiabilite

- Disponibilite 99,9%
- Transactions ACID
- Sauvegarde reguliere des donnees
- Gestion d'erreurs robuste

3 Diagramme de contexte

Le systeme interagit avec :

- L'utilisateur final via une interface web
- La base de donnees PostgreSQL pour la persistance
- Le serveur SMTP pour l'envoi de mails OTP
- Les services externes de paiement

CHAPITRE II

SPECIFICATIONS FONCTIONNELLES ET SECURITAIRES

1 Authentification JWT

1.1 Tokens

Le systeme utilise deux types de tokens :

Type	Duree	Utilite
Access Token	15 minutes	Acces aux endpoints securises
Refresh Token	7 jours	Renouvellement du Access Token

TABLEAU II.1 – Types de tokens JWT

1.2 Securite des tokens

- Signature HMAC-SHA256
- Impossible a falsifier
- Validation stricte a chaque requete
- Protection contre le session hijacking

2 Systeme OTP (One-Time Password)

2.1 Utilisation

L'OTP est requis pour :

- Activation du compte
- Transaction bancaire
- Mise a jour de donnees sensibles

2.2 Caracteristiques

Parametre	Valeur
Format	6 chiffres
Duree de validite	5 minutes
Tentatives maximales	3
Stockage	Hache (jamais en clair)

TABLEAU II.2 – Specifications de l'OTP

3 Gestion des permissions

Chaque action sensible verifie :

```
1 if account.user == request.user:
2     # Autoriser l'action
3 else:
4     # Refuser l'accès
```

Cela assure :

- Accès uniquement aux données propres
- Prevention de l'usurpation d'identite
- Conformite RGPD

CHAPITRE III

CONCEPTION TECHNIQUE

1 Architecture generale

1.1 Stack technologique

Couche	Technologie
Backend	Django REST Framework 3.14+
Frontend	React 18+ avec JSX et Tailwind CSS
Base de données	PostgreSQL 13+
Authentification	Django SimpleJWT
Communication	REST API via HTTP(S)
Mailing	SMTP (Python smtplib)

TABLEAU III.1 – Stack technologique utilisée

1.2 Architecture en couches

Le systeme est organise selon une architecture en couches :

- **Couche Presentation** - React frontend avec composants interactifs

- **Couche API** - Django REST pour les endpoints securises
- **Couche Logique Metier** - Services Django avec regles de gestion
- **Couche Donnees** - PostgreSQL avec ORM Django

2 Diagramme de classes global

2.1 Description

Le diagramme de classes global présente la structure statique du système **Secure-Bank**. Il décrit les principales entités métiers, les composants de sécurité ainsi que les relations entre ces éléments.

- **Classes métier** : User, BankAccount, Beneficiary, Transaction
- **Classes de sécurité et de contrôle** : OTP, AuditLog
- **Relations** : associations entre utilisateurs, comptes, bénéficiaires et transactions

Ce diagramme permet de comprendre l'organisation globale du système et sert de base aux autres diagrammes UML.

2.2 Inclusion du diagramme

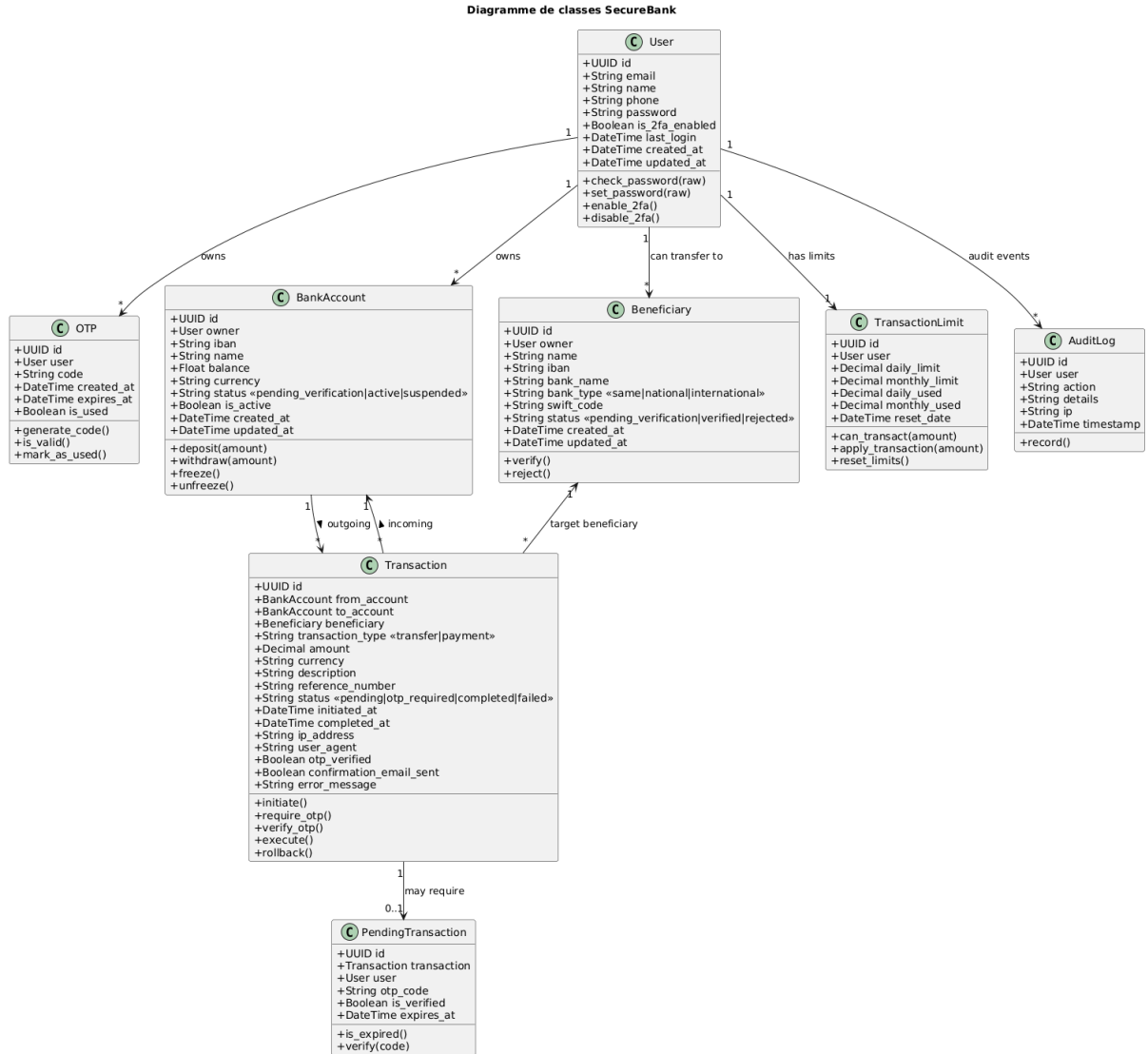


FIGURE III.1 – Diagramme de classes principal – SecureBank

3 Diagrammes de séquence

Les diagrammes de séquence illustrent les interactions dynamiques entre les acteurs (Utilisateur) et les composants du système pour les principaux cas d'utilisation.

3.1 Séquence : Connexion / Inscription (Sign Up / Sign In)

Ce diagramme décrit le processus d'inscription et d'authentification de l'utilisateur, incluant la vérification des identifiants et l'accès sécurisé à l'application.

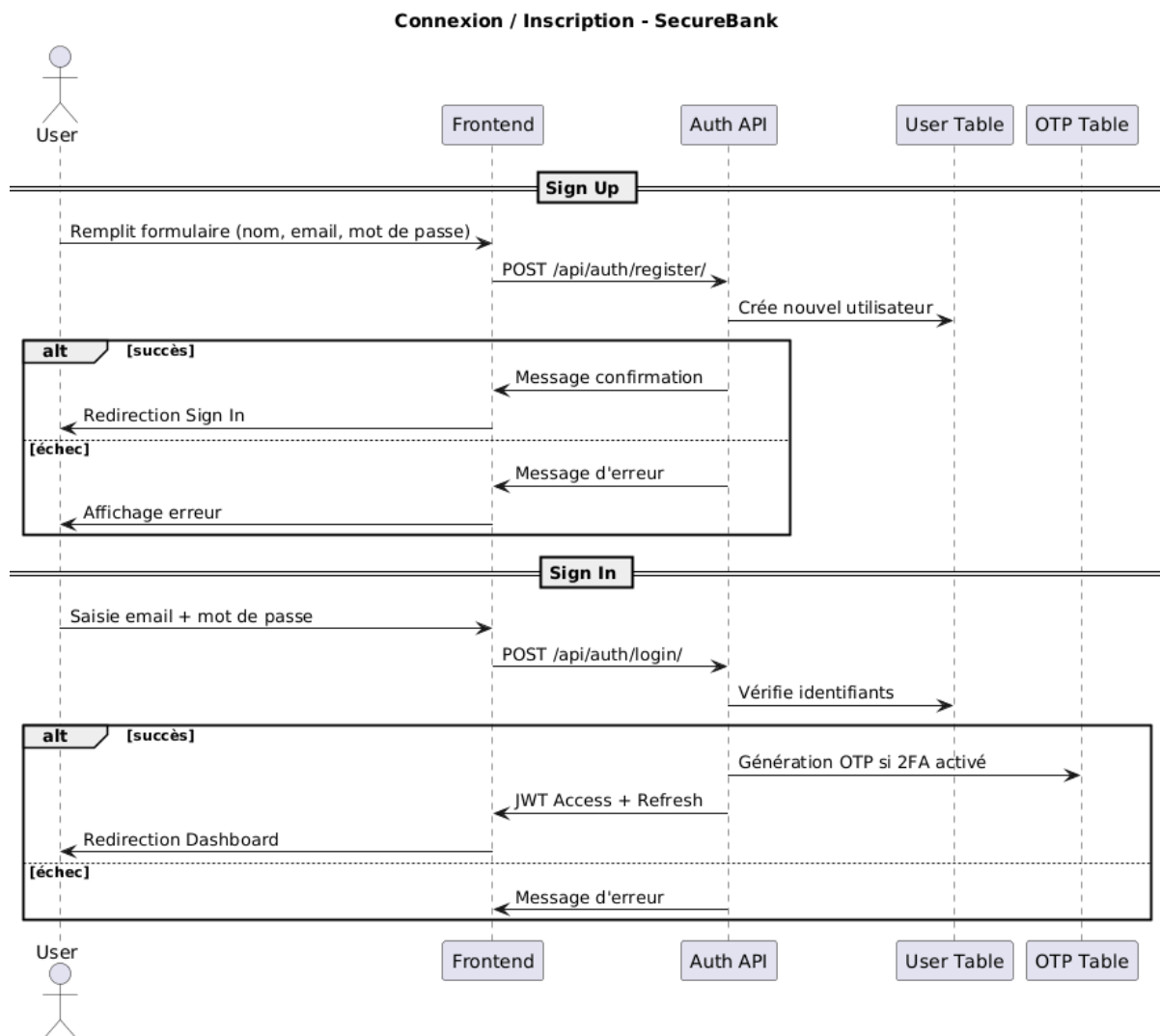


FIGURE III.2 – Diagramme de séquence – Connexion / Inscription

3.2 Séquence : Gestion des bénéficiaires

Ce diagramme présente l'ajout, la consultation et la validation d'un bénéficiaire par l'utilisateur.

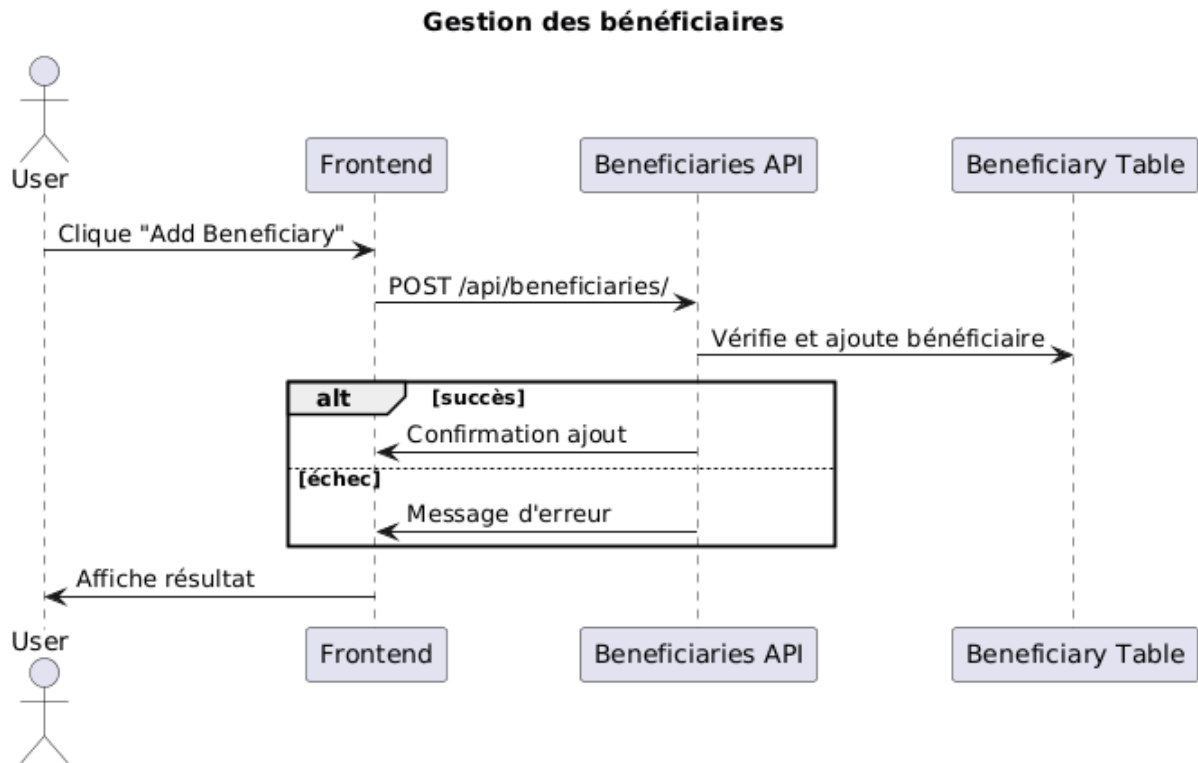


FIGURE III.3 – Diagramme de séquence – Gestion des bénéficiaires

3.3 Séquence : Virement avec OTP

Ce diagramme illustre le processus complet d'un virement bancaire incluant la génération et la vérification du code OTP avant l'exécution de la transaction.

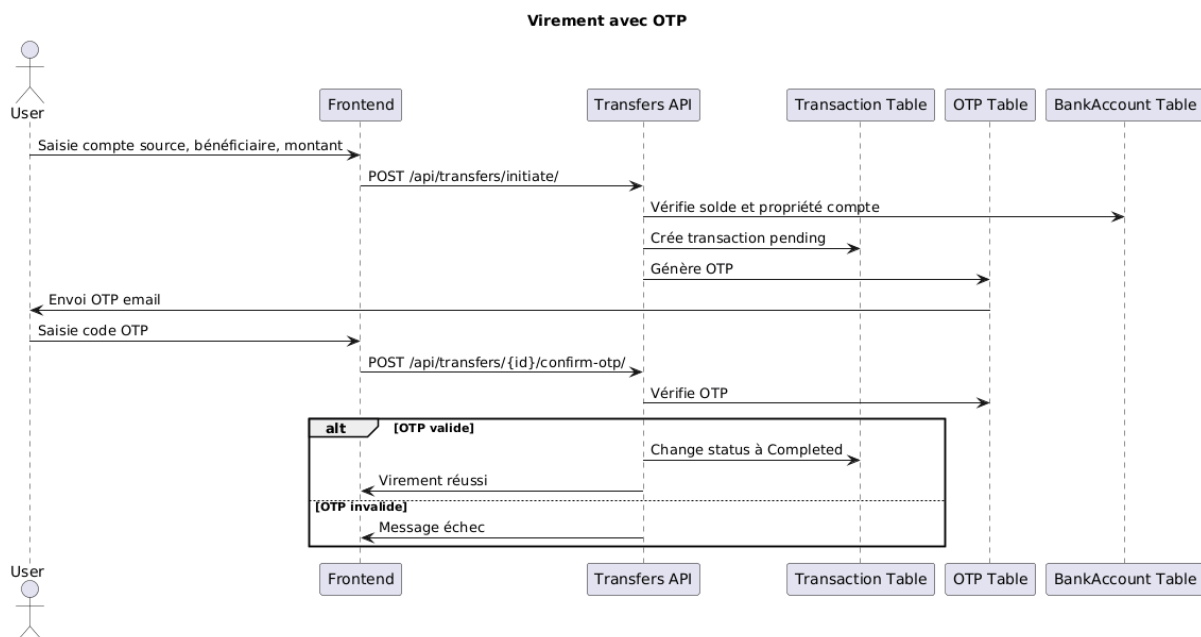


FIGURE III.4 – Diagramme de séquence – Virement avec OTP

3.4 Séquence : Historique des transactions

Ce diagramme montre la consultation de l'historique des transactions effectuées par l'utilisateur.

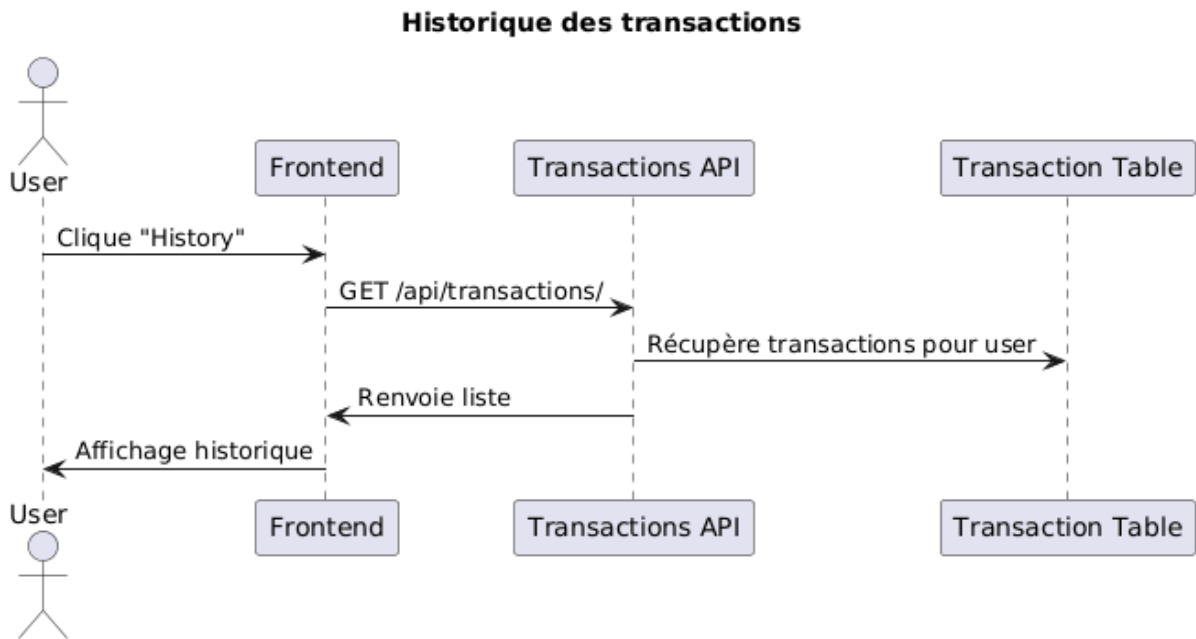


FIGURE III.5 – Diagramme de séquence – Historique des transactions

3.5 Séquence : Paramètres Profil & Sécurité

Ce diagramme décrit la gestion du profil utilisateur, incluant la modification des informations personnelles, le changement de mot de passe, l'activation/désactivation du 2FA et la déconnexion.

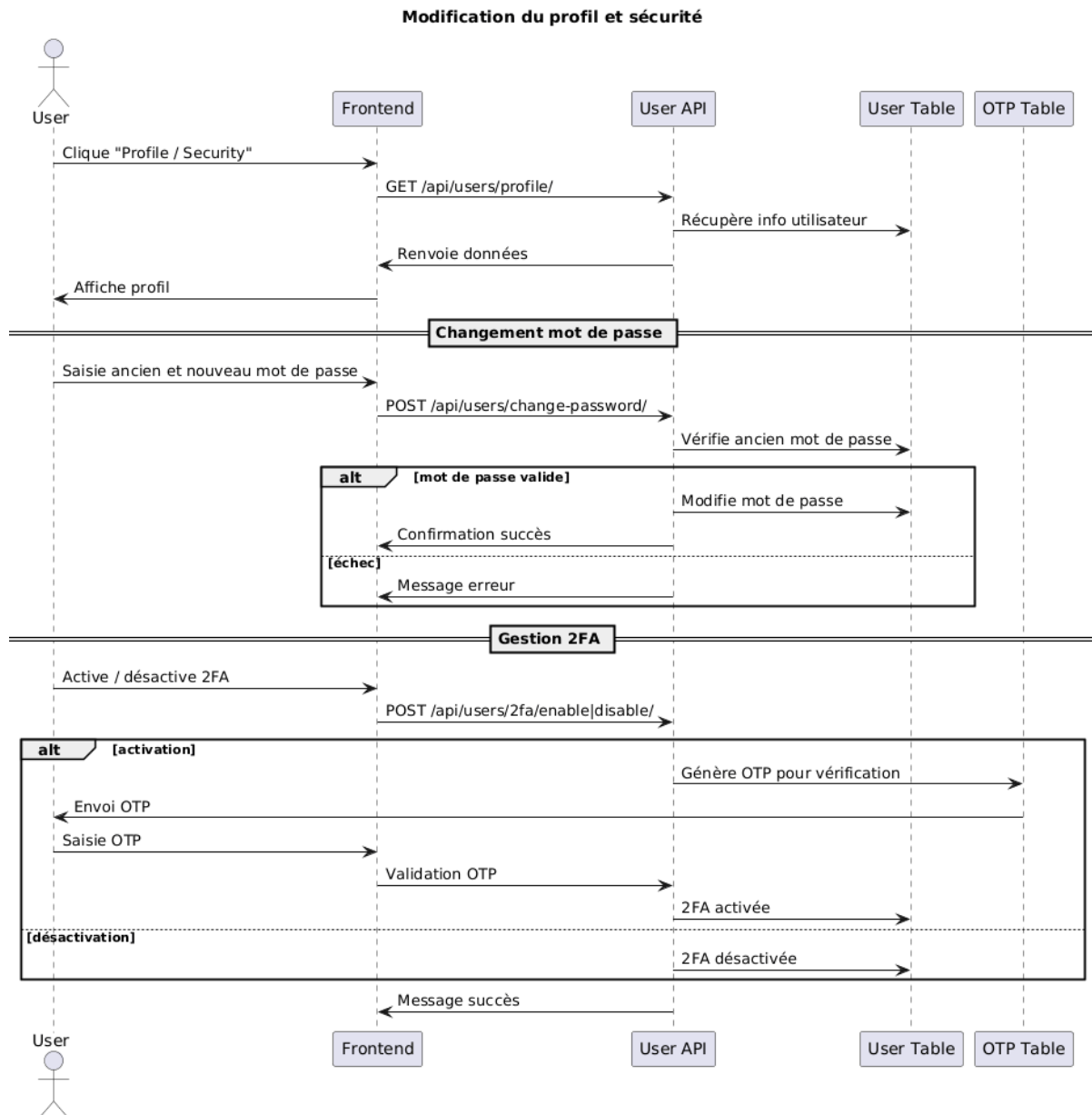


FIGURE III.6 – Diagramme de séquence – Paramètres Profil et Sécurité

3.6 Séquence générale du flux de l'application

Ce diagramme fournit une vue d'ensemble du flux général de l'application SecureBank, depuis la connexion de l'utilisateur jusqu'à l'exécution des principales fonctionnalités.

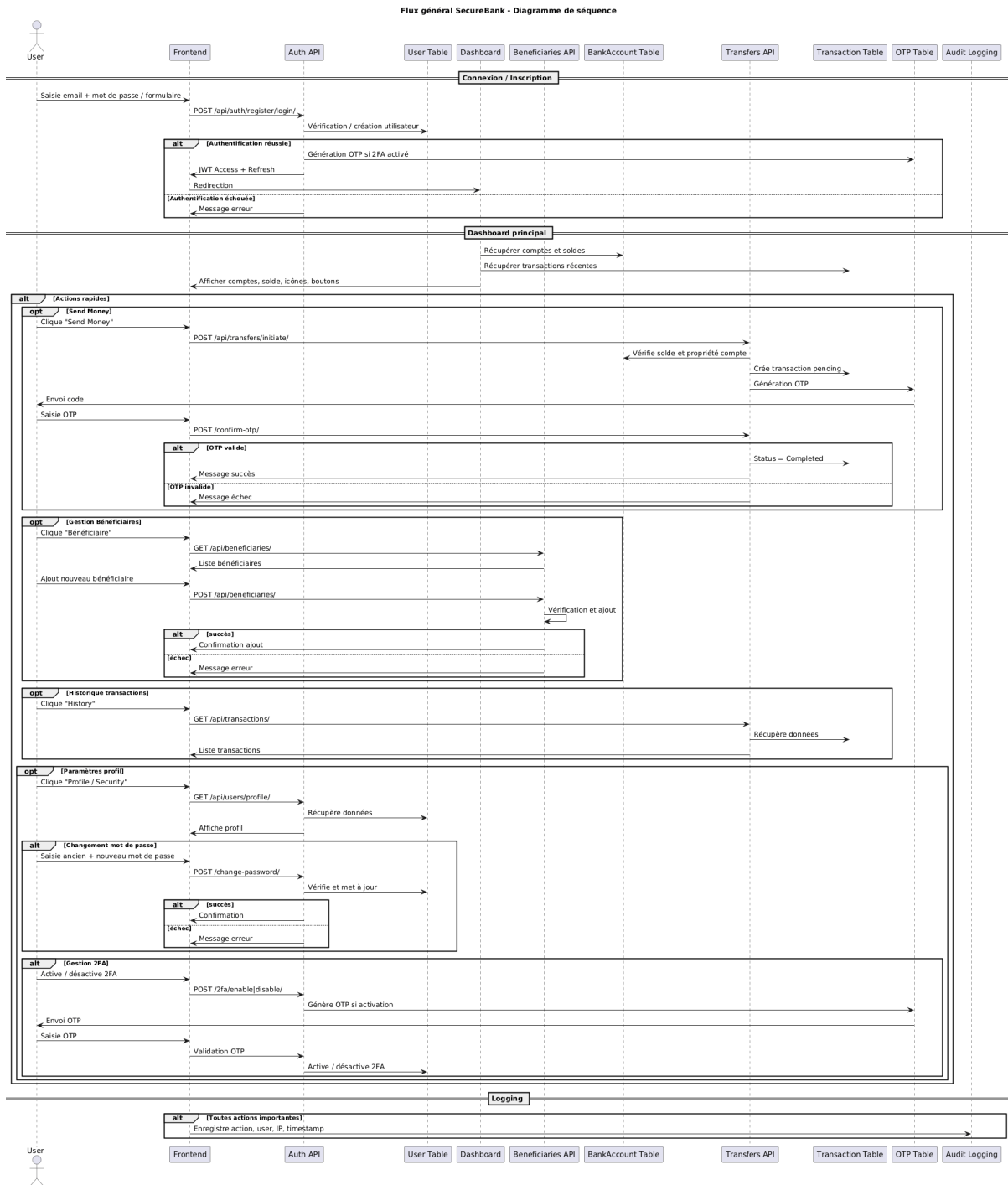


FIGURE III.7 – Diagramme de séquence – Flux général de l'application SecureBank

4 Diagramme d'état

4.1 État d'une transaction – SecureBank

Le diagramme d'état ci-dessous illustre le cycle de vie d'une transaction bancaire dans l'application *SecureBank*, depuis sa création jusqu'à son aboutissement ou son échec. Il met en évidence les différents états de la transaction ainsi que les transitions liées aux actions de l'utilisateur et aux mécanismes de sécurité.

- **Draft** : Transaction créée mais non soumise.
- **PendingOTP** : En attente de validation par code OTP.
- **Verified** : OTP validé avec succès.
- **Processing** : Transaction en cours de traitement.
- **Completed** : Transaction exécutée avec succès.
- **Failed** : Transaction échouée.
- **Cancelled** : Transaction annulée par l'utilisateur.

Diagramme d'état d'une transaction - SecureBank

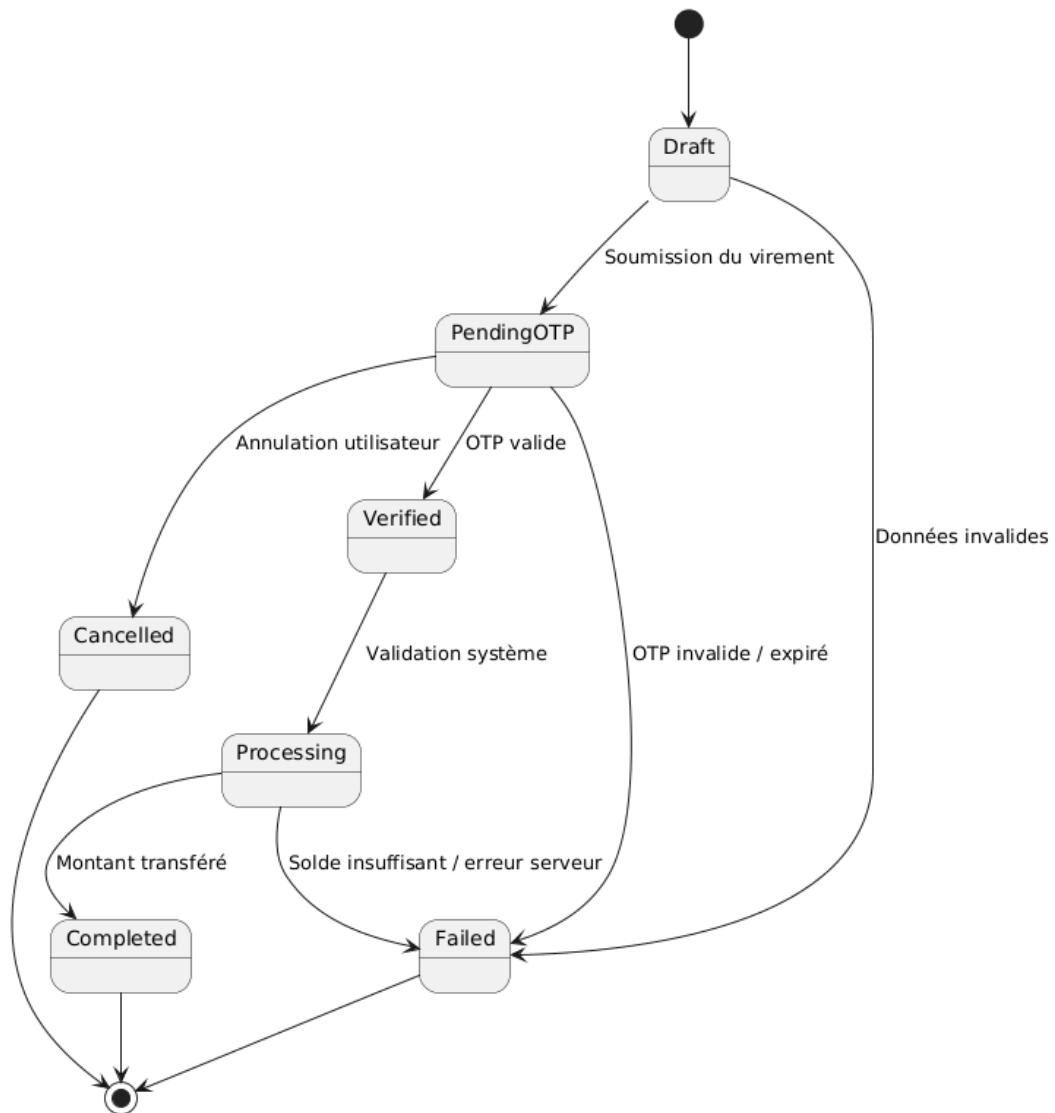


FIGURE III.8 – Diagramme d'état – Cycle de vie d'une transaction SecureBank

CHAPITRE IV

CONCEPTION SECURISEE

1 Protection des mots de passe

1.1 Algorithme de hachage

Les mots de passe sont proteges avec :

- **Algorithme** : PBKDF2 + SHA-256
- **Iterations** : 600000 (par default Django)
- **Sel** : Unique par utilisateur
- **Stockage** : Jamais en clair

1.2 Code exemple

```
1 from django.contrib.auth.hashers import make_password
2
3 password = "MySecurePassword123!"
4 hashed = make_password(password)
5 # Stockage du hashed uniquement en BD
```

2 Generation securisee des OTP

2.1 Caracteristiques de securite

- Genere via secrets (cryptographiquement securise)

- 6 chiffres aleatoires
- Hache avant stockage en BD
- Jamais stocke en clair
- Impredictible et non predictable

2.2 Validation des OTP

Etapes :

- Verifier existence
- Verifier expiration (5 min)
- Verifier nombre de tentatives (max 3)
- Comparer le hash OTP
- Marquer comme utilise
- Effectuer l'action

3 Securite des comptes bancaires

3.1 Creation automatique

A la premiere connexion :

- Creation d'un compte bancaire unique
- Generation d'un IBAN securise
- Statut : pending_verification
- Lien automatique a l'utilisateur

3.2 Verification de propriete

```
1 # Verification stricte
2 if account.user != request.user:
3     return Response(
4         {"error": "Acces non autorise"},
5         status=403
6     )
```

4 Chiffrement TLS/SSL

4.1 Configuration

- `SECURE_SSL_REDIRECT = True`
- `SESSION_COOKIE_SECURE = True`
- `CSRF_COOKIE_SECURE = True`
- Certificat SSL valide
- HTTPS enforced partout

5 Audit Logging

Chaque action critique enregistre :

- **User** - Utilisateur qui a effectue l'action
- **IP** - Adresse IP source
- **Device** - Informations du navigateur
- **Action** - Type d'action effectuee
- **Timestamp** - Date et heure exacte
- **Status** - Succes ou echec

CHAPITRE V

DEVELOPPEMENT DE L'APPLICATION

1 Backend Django

```
secure_banking_backend/  
|-- manage.py  
|-- requirements.txt  
|-- .env  
|-- banking_app/  
|   |-- settings.py  
|   |-- urls.py  
|-- security/  
|   |-- models.py  
|   |-- views.py  
|   |-- serializers.py  
|-- accounts/  
|   |-- models.py  
|   |-- views.py  
|   |-- serializers.py  
|-- transactions/  
|   |-- models.py  
|   |-- views.py  
|   |-- serializers.py  
|-- audit/  
    |-- models.py
```

1.1 Endpoints API principaux

Type	Endpoint	Description
POST	/api/auth/register/	Créer un compte utilisateur (public)
POST	/api/auth/login/	Authentification utilisateur avec jeton JWT
POST	/api/auth/refresh-token/	Renouvellement sécurisé du token JWT
POST	/api/auth/logout/	Déconnexion sécurisée de l'utilisateur
GET	/api/accounts/	Liste des comptes bancaires (accessible après authentification)
GET	/api/accounts/{account_id}/	Détails d'un compte bancaire (authentification requise)
GET	/api/beneficiaries/	Liste des bénéficiaires autorisés (authentification requise)
POST	/api/beneficiaries/	Ajout sécurisé d'un bénéficiaire (authentification requise)
POST	/api/transfers/initiate/	Initier un virement bancaire (authentification requise)
POST	/api/transfers/{transfer_id}/confirm-otp/	Valider un virement par code OTP pour authentification forte
GET	/api/transactions/	Consultation de l'historique des transactions (authentification requise)
GET	/api/security/login-events/	Consultation des événements de connexion
GET	/api/security/failed-attempts/	Suivi des tentatives d'authentification échouées
POST	/api/security/logout-all-devices/	Déconnexion forcée de tous les appareils actifs
GET	/api/users/profile/	Consulter le profil utilisateur (authentification requise)
PATCH	/api/users/profile/	Modifier le profil utilisateur (authentification requise)
POST	/api/users/change-password/	Changer le mot de passe (authentification requise)
POST	/api/users/2fa/enable/	Activer la double authentification (2FA)
POST	/api/users/2fa/disable/	Désactiver la double authentification (2FA avec OTP)

TABLEAU V.1 – Tableau V.1 – Endpoints API backend

2 Frontend React

2.1 Description generale

L'interface frontend est developpee en React 18+ et offre une experience utilisateur fluide et securisee.

2.2 Pages principales

L'application frontend comporte plusieurs écrans principaux, chacun correspondant à une fonctionnalité clé pour l'utilisateur.

- **Page de connexion (Sign In)** – Permet l'authentification sécurisée des utilisateurs via email et mot de passe.
- **Page de création de compte (Sign Up)** – Permet aux nouveaux utilisateurs de s'inscrire en renseignant leurs informations personnelles.
- **Tableau de bord (Dashboard)** – Affiche les comptes et leurs soldes, propose des actions rapides (virement, gestion des bénéficiaires, historique, profil).
- **Gestion des bénéficiaires** – Permet d'ajouter, modifier ou supprimer les bénéficiaires pour les virements.
- **Effectuer un virement (Send Money)** – Formulaire de transfert sécurisé vers un bénéficiaire enregistré avec confirmation OTP.
- **Vérification OTP** – Étape de sécurité permettant de confirmer un virement via un code OTP envoyé à l'utilisateur.
- **Historique des transactions** – Consultation complète des mouvements financiers, filtrage, pagination et export des données.
- **Paramètres du profil** – Gestion des informations personnelles (email, téléphone, mot de passe) et des options de sécurité.
- **Sécurité et Two-Factor Authentication (2FA)** – Activation ou désactivation de la 2FA, changement de mot de passe et déconnexion de tous les appareils.

2.3 Ecran de Connexion

La page de connexion permet aux utilisateurs de s'authentifier avec leur email et mot de passe.

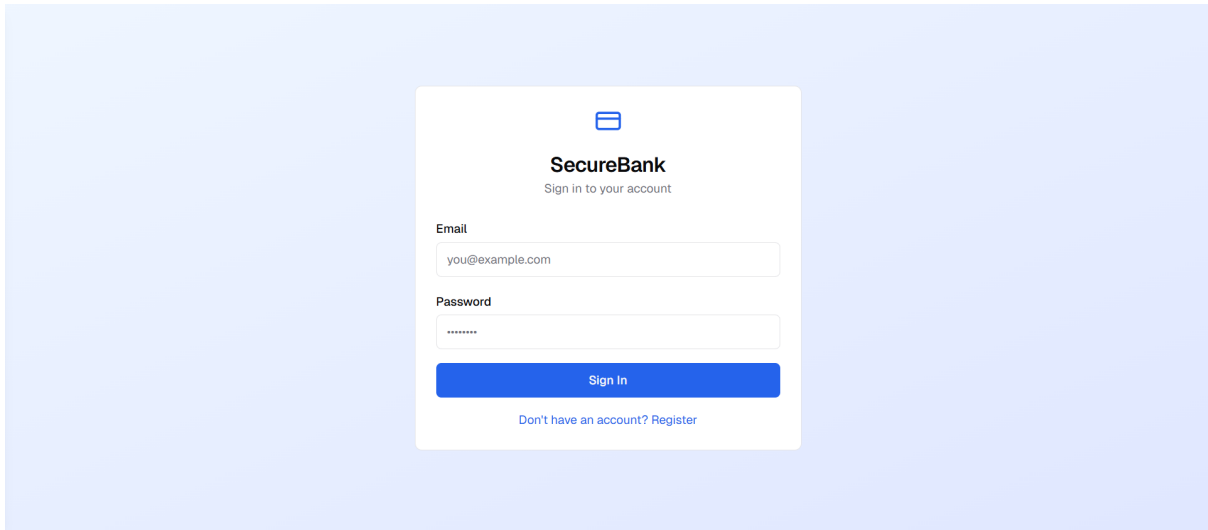


FIGURE V.1 – Interface de connexion - Page de login

Caracteristiques :

- Champs email et mot de passe
- Bouton de connexion securise
- Message d'erreur en cas d'echec
- Lien vers inscription (Register)

2.4 Ecran de creation compte

La page de création de compte permet aux nouveaux utilisateurs de s'inscrire en renseignant leurs informations personnelles afin d'accéder à la plateforme.

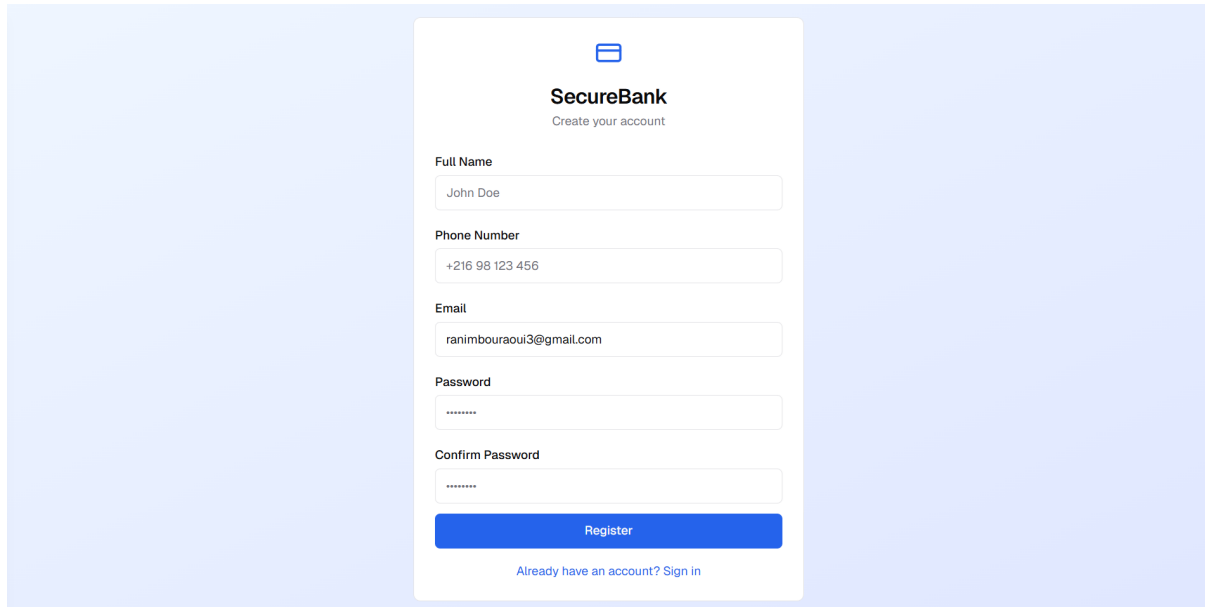
The image shows a registration form for 'SecureBank' centered on a light blue background. The form is white with a blue header containing a bank icon and the text 'SecureBank' and 'Create your account'. It features five input fields: 'Full Name' (with 'John Doe'), 'Phone Number' (with '+216 98 123 456'), 'Email' (with 'ranimbouraoui3@gmail.com'), 'Password' (with masked characters), and 'Confirm Password' (also masked). A blue 'Register' button is at the bottom, followed by a link 'Already have an account? Sign in'.

FIGURE V.2 – Interface de connexion - Page de login

Caractéristiques :

- Champs de saisie : nom et prénom, email et mot de passe
- Confirmation du mot de passe
- Vérification de la validité de l'email
- Règles de sécurité pour le mot de passe
- Bouton de création de compte sécurisé
- Message d'erreur en cas de données invalides
- Message de confirmation après inscription réussie
- Lien de redirection vers l'écran de connexion (Sign In)

2.5 Tableau de Bord

Le tableau de bord affiche les comptes de l'utilisateur et leurs soldes.

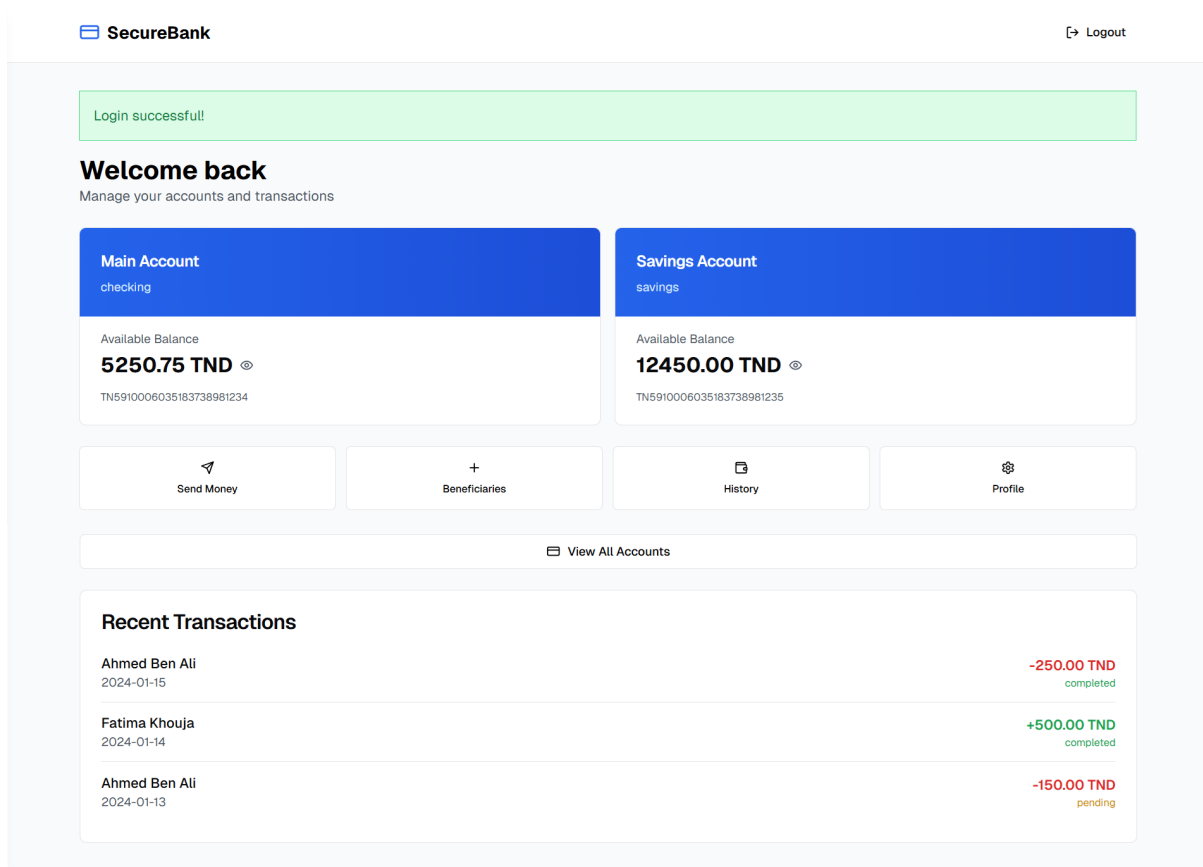


FIGURE V.3 – Tableau de bord

Caractéristiques :

- Message textuel indiquant le succès de la connexion
- Affichage des comptes de l'utilisateur avec leurs soldes
- Icônes de statut des comptes
- Icône *œil* permettant de masquer ou afficher le montant du solde
- Message de bienvenue personnalisé
- Menu de navigation principal
- Boutons d'actions rapides :
 - **Send Money** : effectuer un transfert d'argent
 - **Bénéficiaire** : ajout et gestion des bénéficiaires
 - **History** : consultation de l'historique des transactions
 - **Profile** : accès aux paramètres du compte utilisateur
- Bouton **View All Accounts** permettant d'afficher l'ensemble des comptes bancaires

- Liste des transactions récentes affichée en bas de l'écran

2.6 Affichage des comptes bancaires depuis le tableau de bord

Le bouton **View All Accounts**, accessible depuis le tableau de bord, permet à l'utilisateur d'afficher l'ensemble de ses comptes bancaires dans une fenêtre contextuelle sans quitter l'écran principal.

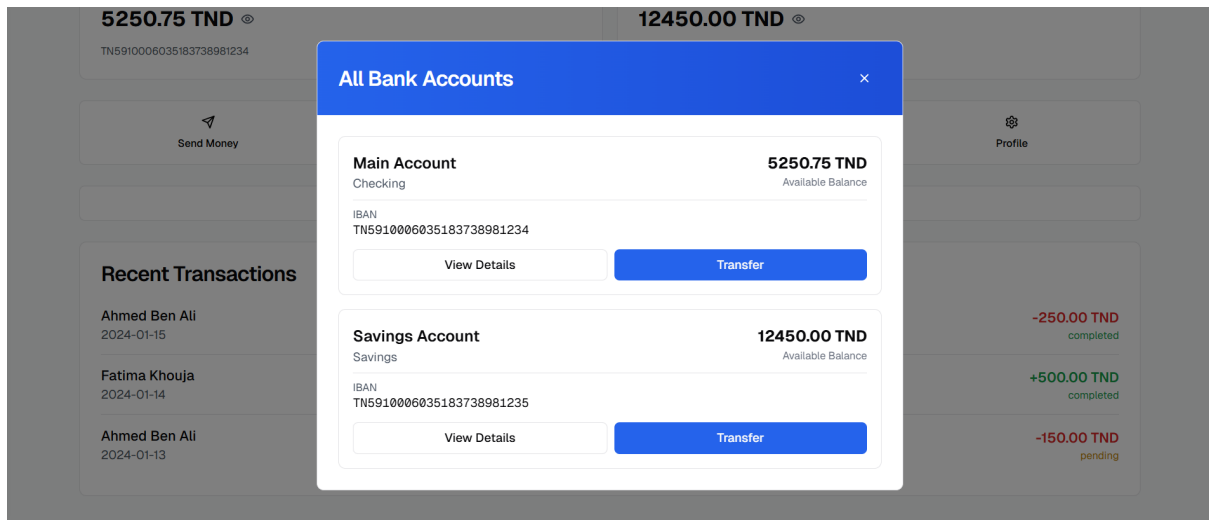


FIGURE V.4 – Popup affichant tous les comptes bancaires

Caractéristiques :

- Ouverture d'un popup depuis le tableau de bord
- Affichage de la liste complète des comptes bancaires de l'utilisateur
- Informations affichées pour chaque compte :
 - Nom de la banque
 - Type de compte
 - Numéro du compte
 - Solde disponible
- Bouton **View Details** permettant de consulter les informations détaillées du compte sélectionné
- Bouton **Transfer** permettant d'effectuer un virement à partir du compte choisi
- Fermeture du popup après action ou via un bouton de fermeture

2.7 Gestion des bénéficiaires

Cette interface permet à l'utilisateur de gérer les bénéficiaires utilisés pour effectuer des virements bancaires. L'accès à cette fonctionnalité se fait depuis le tableau de bord via le bouton **Bénéficiaire**.

2.7.1 Liste des bénéficiaires

Après avoir cliqué sur le bouton **Bénéficiaire** depuis le tableau de bord, l'utilisateur est redirigé vers la page de gestion des bénéficiaires, qui affiche l'ensemble des bénéficiaires déjà enregistrés.

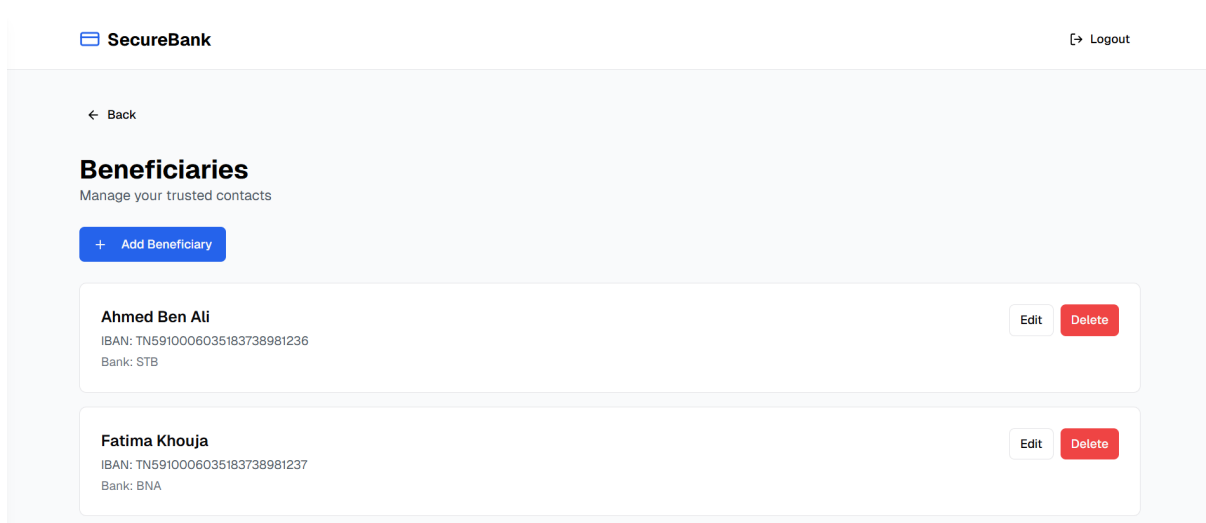


FIGURE V.5 – Page de gestion des bénéficiaires

Caractéristiques :

- Affichage de la liste des bénéficiaires enregistrés
- Informations affichées pour chaque bénéficiaire :
 - Nom du bénéficiaire
 - IBAN
 - Nom de la banque
- Bouton **Add Beneficiaries** permettant l'ajout d'un nouveau bénéficiaire

2.7.2 Ajout d'un nouveau bénéficiaire

En cliquant sur le bouton **Add Beneficiaries**, un formulaire s'affiche permettant à l'utilisateur d'ajouter un nouveau bénéficiaire.

Beneficiaries
Manage your trusted contacts

Add New Beneficiary

Beneficiary Name
Mahmoud Ben Abdelkader

IBAN
TNS912206035183738981242

Bank Name
STB

Add Beneficiary Cancel

Back

FIGURE V.6 – Formulaire d'ajout d'un bénéficiaire

Caractéristiques :

- Champs de saisie :
 - Nom du bénéficiaire
 - IBAN
 - Nom de la banque
- Bouton **Add Beneficiary** pour valider l'ajout
- Bouton **Cancel** pour annuler l'opération
- Vérification de la validité des informations saisies
- Message de confirmation après l'ajout réussi

2.8 Interface de virement

Cette interface permet à l'utilisateur d'effectuer un virement bancaire sécurisé vers un bénéficiaire enregistré. L'accès à cette fonctionnalité se fait depuis le tableau de bord via le bouton **Send Money**.

2.8.1 Formulaire de virement

Après avoir cliqué sur le bouton **Send Money**, l'utilisateur est redirigé vers la page de virement où il doit compléter les informations nécessaires à la transaction.

← Back

Send Money

Transfer funds to your beneficiaries

Select Account

Main Account
Balance: 5250.75 TND

Savings Account
Balance: 12450.00 TND

Select Beneficiary

Ahmed Ben Ali
IBAN: TN5910006035183738981236
Bank: STB

Fatima Khouja
IBAN: TN5910006035183738981237
Bank: BNA

Transfer Amount

Amount (TND)

Complete All Fields to Continue

Back

FIGURE V.7 – Formulaire de virement avant remplissage

Caractéristiques :

- Sélection du compte source à partir des comptes de l'utilisateur
- Sélection du bénéficiaire depuis la liste des bénéficiaires enregistrés
- Saisie du montant à transférer
- Champ de description de la transaction
- Bouton **Complete all fields to continue** désactivé tant que le formulaire n'est pas complet

2.8.2 Confirmation du virement

Une fois tous les champs du formulaire correctement renseignés, le bouton change d'état et permet à l'utilisateur de passer à l'étape de confirmation.

← Back

Send Money

Transfer funds to your beneficiaries

Select Account

Main Account
Balance: 5250.75 TND

Savings Account
Balance: 12450.00 TND

Select Beneficiary

Ahmed Ben Ali
IBAN: TN5910006035183738981236
Bank: STB

Fatima Khouja
IBAN: TN5910006035183738981237
Bank: BNA

Transfer Amount

Amount (TND)

You will transfer: 2000.00 TND

Continue to Confirm

Back

FIGURE V.8 – Formulaire de virement après remplissage

Caractéristiques :

- Activation du bouton **Continue to confirm**
- Vérification de la validité des informations saisies
- Passage à l'étape de confirmation du virement

2.9 Vérification OTP

Après la confirmation d'un virement, l'utilisateur doit valider la transaction à l'aide d'un code OTP (One-Time Password) afin de renforcer la sécurité de l'opération.

2.9.1 Écran de vérification OTP – Avant saisie

Un premier écran invite l'utilisateur à confirmer la transaction en affichant les détails du virement ainsi que le champ de saisie du code OTP.

Please confirm your transaction with OTP

\$ TRANSACTION DETAILS

From Account	Main Account
To Beneficiary	Fatima Khouja
Amount	2000.00 TND

Enter Security Code Encrypted

● ● ● ● ● ●

Code sent to ranimbouraoui3@gmail.com 3:51

Resend available after timer expires

Cancel **Enter OTP**

FIGURE V.9 – Écran de vérification OTP – Avant saisie du code

Caractéristiques :

- Message demandant la confirmation de la transaction par OTP
- Affichage des détails de la transaction :
 - Compte source
 - Bénéficiaire
 - Montant du virement
- Indication de l'envoi du code OTP à l'adresse email de l'utilisateur
- Champ de saisie pour le code OTP à 6 chiffres
- Minuteur indiquant la durée de validité du code
- Lien pour le renvoi du code après expiration du minuteur
- Bouton **Cancel** pour annuler l'opération

2.9.2 Écran de vérification OTP – Après saisie

Une fois le code OTP saisi, l'utilisateur peut valider définitivement la transaction.

The screenshot shows a mobile application interface for OTP verification. At the top, a blue banner reads "Please confirm your transaction with OTP". Below this, a section titled "\$ TRANSACTION DETAILS" contains a table with transaction information: "From Account" is "Main Account", "To Beneficiary" is "Fatima Khouja", and "Amount" is "2000.00 TND". Underneath, there is a section "Enter Security Code" with a green "Encrypted" label. A large input field displays the entered code "1 2 3 8 7 4" with a green checkmark on the right. Below the code field, a message states "Code sent to ranimbouraoui3@gmail.com" with a clock icon and "3:19". A note below says "Resend available after timer expires". At the bottom, there are two buttons: "Cancel" and "Verify & Confirm".

\$ TRANSACTION DETAILS	
From Account	Main Account
To Beneficiary	Fatima Khouja
Amount	2000.00 TND

Enter Security Code Encrypted

1 2 3 8 7 4 ✓

Code sent to ranimbouraoui3@gmail.com 3:19

Resend available after timer expires

Cancel Verify & Confirm

FIGURE V.10 – Écran de vérification OTP – Après saisie du code

Caractéristiques :

- Affichage du code OTP saisi par l'utilisateur
- Activation du bouton **Verify & Confirm**
- Vérification du code OTP avant exécution du virement
- Maintien du minuteur de validité du code
- Confirmation finale de la transaction après validation correcte

2.10 Historique des transactions

Cette interface permet à l'utilisateur de consulter l'historique complet de ses transactions bancaires. L'accès se fait depuis le tableau de bord via le bouton **History**.

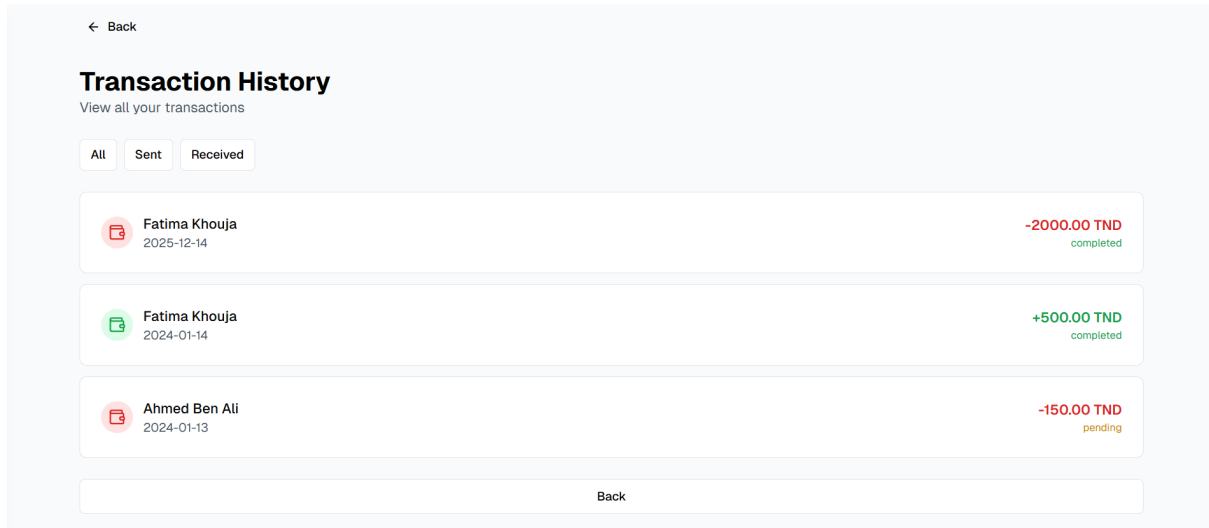


FIGURE V.11 – Historique des transactions bancaires

Caractéristiques :

- Affichage des transactions dans un tableau structuré
- Colonnes principales :
 - Type de transaction (Envoyé / Reçu)
 - Nom du bénéficiaire ou de l'expéditeur
 - Date de la transaction
 - Montant (positif ou négatif)
 - Statut de la transaction (Completed / Pending)
- Pagination pour faciliter la consultation
- Bouton **Back** pour revenir au tableau de bord

2.11 Paramètres du profil

Cette interface permet à l'utilisateur de gérer ses informations personnelles et ses paramètres de sécurité.

SecureBank Logout

[← Back](#)

Profile Settings

Manage your account information

Personal Information

Email Address
ranimbouaoul3@gmail.com

Full Name

Phone Number

[Save Changes](#)

Security

Two-Factor Authentication
2FA is currently enabled [Disable](#)

Last login: December 15, 2025 at 10:30 AM

[Change Password](#)

[Logout from all devices](#)

[Sign Out](#)

[Back](#)

FIGURE V.12 – Page des paramètres du profil utilisateur

Caractéristiques :

- Affichage des informations personnelles (Nom, Email, Téléphone)
- Modification de l'email
- Modification du numéro de téléphone
- Changement du mot de passe
- Gestion de la sécurité (Two-Factor Authentication)
- Bouton de déconnexion (Logout)
- Confirmation des modifications après sauvegarde

2.12 Sécurité et Two-Factor Authentication (2FA)

Cette section permet à l'utilisateur de gérer les options de sécurité avancées, notamment la vérification en deux étapes et le changement de mot de passe.

2.12.1 2FA activée

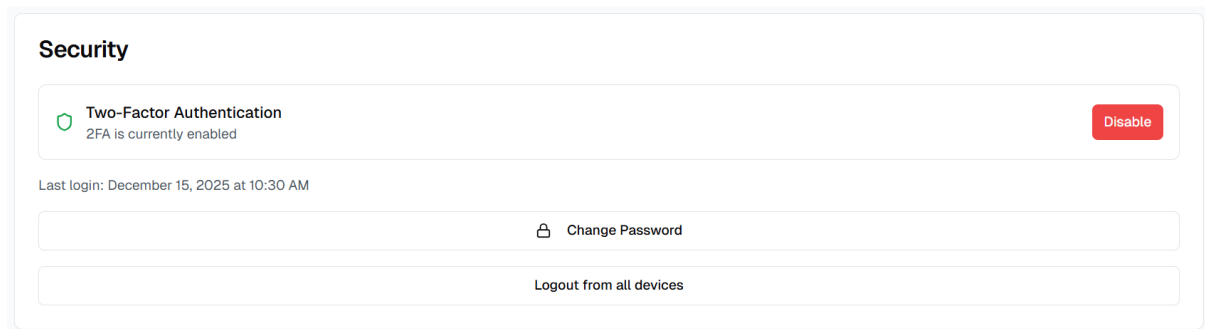


FIGURE V.13 – Paramètres de sécurité avec 2FA activée

Caractéristiques :

- Affichage de l'état actuel de la 2FA (activée)
- Dernière connexion affichée
- Bouton **Disable** pour désactiver la 2FA
- Accès aux options de changement de mot de passe
- Bouton pour se déconnecter de tous les appareils

2.12.2 2FA désactivée

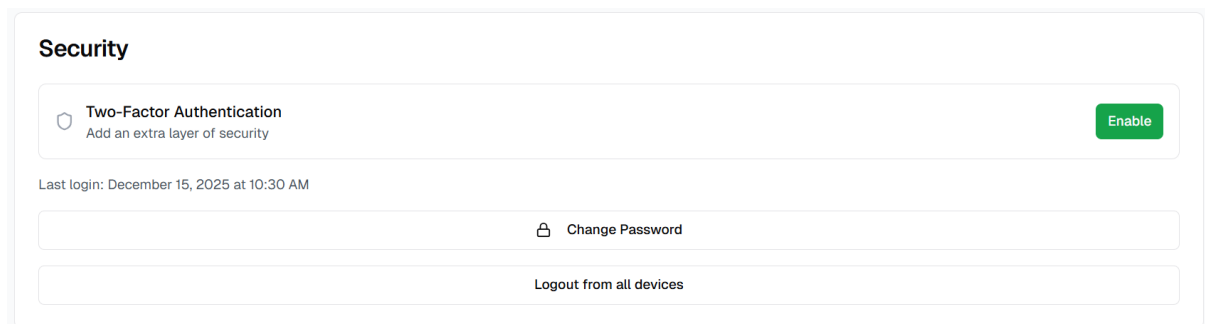
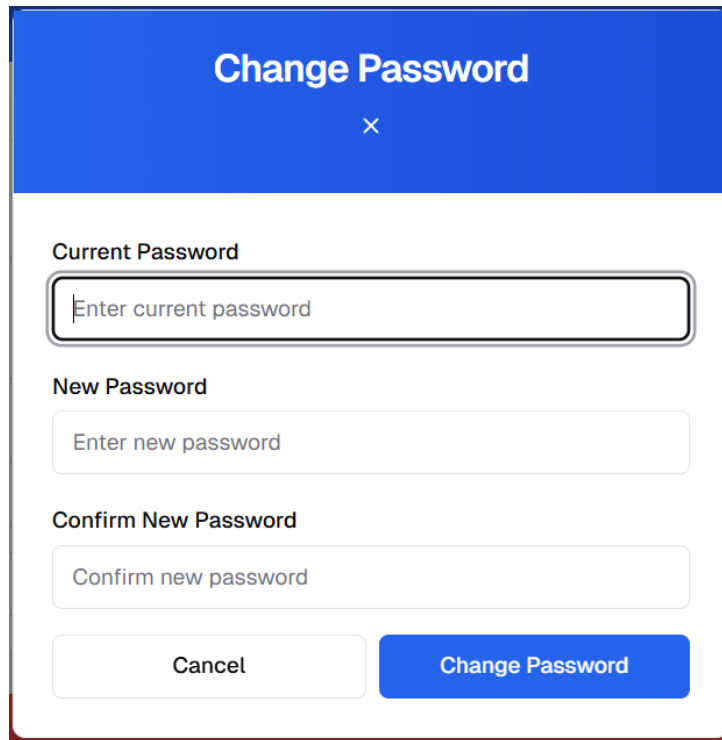


FIGURE V.14 – Paramètres de sécurité avec 2FA désactivée

Caractéristiques :

- Affichage de l'état actuel de la 2FA (désactivée)
- Option **Enable** pour activer la 2FA
- Accès au changement de mot de passe et déconnexion

2.12.3 Changement de mot de passe



The image shows a 'Change Password' dialog box. It has a blue header with the title 'Change Password' and a close button (X). Below the header, there are three input fields: 'Current Password' with a placeholder 'Enter current password', 'New Password' with a placeholder 'Enter new password', and 'Confirm New Password' with a placeholder 'Confirm new password'. At the bottom, there are two buttons: 'Cancel' and 'Change Password'.

Change Password

×

Current Password

Enter current password

New Password

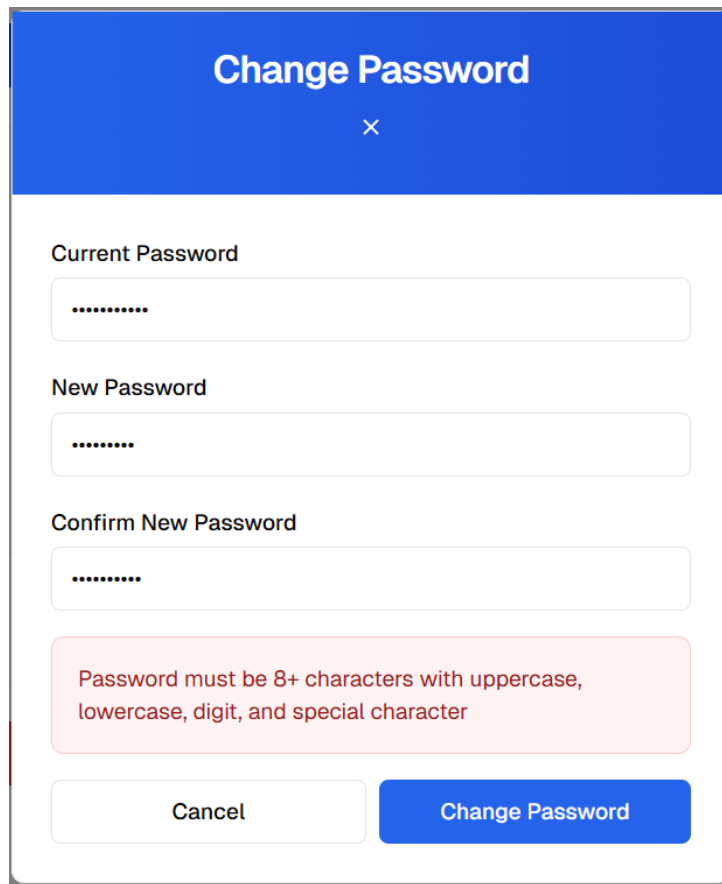
Enter new password

Confirm New Password

Confirm new password

Cancel Change Password

FIGURE V.15 – Formulaire de changement de mot de passe



The image shows a 'Change Password' dialog box. It has a blue header with the title 'Change Password' and a close button (X). Below the header, there are three input fields: 'Current Password', 'New Password', and 'Confirm New Password'. Each field contains a series of dots representing masked text. Below the input fields, there is a red-bordered box containing a validation message: 'Password must be 8+ characters with uppercase, lowercase, digit, and special character'. At the bottom, there are two buttons: 'Cancel' and 'Change Password'.

FIGURE V.16 – Formulaire de changement de mot de passe avec contrôle de saisie

Caractéristiques :

- Saisie du mot de passe actuel
- Saisie du nouveau mot de passe
- Confirmation du nouveau mot de passe
- Contrôle de validité du mot de passe : minimum 8 caractères, majuscules, minuscules, chiffres et caractères spéciaux
- Bouton **Cancel** pour annuler l'opération
- Bouton **Change Password** pour valider la modification

2.12.4 Déconnexion

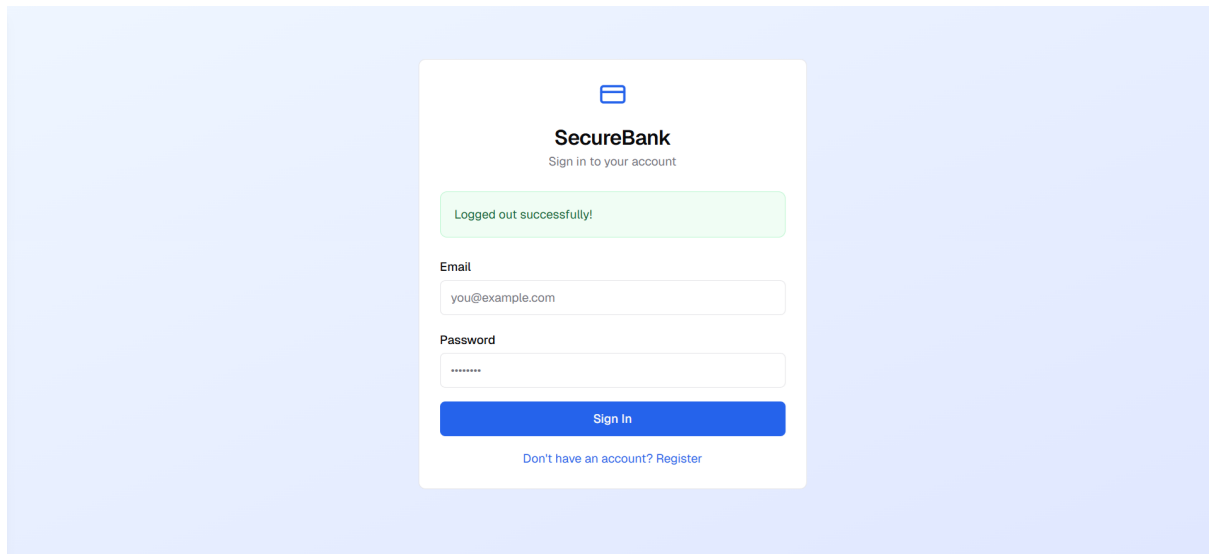


FIGURE V.17 – Option de déconnexion du profil utilisateur

Caractéristiques :

- Déconnexion de tous les appareils
- Bouton **Sign Out** pour terminer la session en cours

3 Bases de donnees

3.1 PostgreSQL

Avantages de securite :

- Foreign Keys strictes
- Contraintes uniques
- Transactions ACID
- Permissions par utilisateur
- Protection contre injections SQL

CHAPITRE VI

TESTS DE SECURITE

1 Methodologie

Les tests couvrent :

- SQL Injection
- Brute Force OTP
- Acces non autorise
- XSS (Cross-Site Scripting)
- CSRF (Cross-Site Request Forgery)
- Session Hijacking

2 Test 1 : Prevention SQL Injection

2.1 Scenario

Tentative d'injection SQL lors de la recherche :

```
GET /api/beneficiaries/?search='; DROP TABLE beneficiaries;--
```

2.2 Resultats

Critere	Resultat
Injection detectee	✓
Base de donnees protegee	✓
Erreur loggee	✓
Reponse securisee	400 Bad Request

TABLEAU VI.1 – Resultats du test SQL Injection

3 Test 2 : Protection contre Brute Force OTP

3.1 Scenario

Tentative de 5 OTP incorrects :

Tentative 1: OTP = 000000 -> Rejet

Tentative 2: OTP = 111111 -> Rejet

Tentative 3: OTP = 222222 -> Rejet

Tentative 4: OTP = 333333 -> Compte verouille

Tentative 5: OTP valide -> Acces refuse

3.2 Resultats

Critere	Resultat
Limite 3 tentatives	✓
Compte verrouille apres	✓
Rate limiting actif	✓
Logs enregistres	✓

TABLEAU VI.2 – Resultats du test Brute Force

4 Synthese des tests

Test	Statut	Notes
SQL Injection	✓	Protege par ORM
Brute Force OTP	✓	Rate limiting
Acces non autorise	✓	Permissions verifiees
XSS	✓	React echappe donnees
CSRF	✓	Middleware actif
Session Hijacking	✓	JWT securise

TABLEAU VI.3 – Synthese de tous les tests

CONCLUSION GÉNÉRALE

Ce projet nous a permis de concevoir et développer une application bancaire moderne, sécurisée et conforme aux standards actuels. L'architecture repose sur Django REST pour le backend, React JSX avec Tailwind pour le frontend et PostgreSQL pour la persistance des données. Les mécanismes de sécurité, tels que l'authentification JWT, la vérification OTP, le hachage des mots de passe et le chiffrement TLS/SSL, garantissent la protection des informations sensibles. La solution mise en œuvre allie fiabilité, performance et traçabilité grâce à l'audit logging et aux bonnes pratiques de développement sécurisé, offrant ainsi une expérience utilisateur sécurisée et robuste.